

Prompt Injection is Not an AI Problem: Why MCP Tool Hardening I

Authors: Shiqiang Chen (Independent Researcher)

Abstract

We demonstrate that prompt-level filtering provides only 50% protection against injection attacks, while simple input va

!

Key Findings

Why Prompt Filtering Fails

- JSON-nested tool calls bypass structure filters
- Multilingual injection bypasses keyword filters
- Benign-looking paths are indistinguishable from malicious ones

Why Tool Hardening Works

One line of code eliminates the entire class of prompt-injection-to-path-traversal attacks:

```
def validate_safe_path(path, base_dir):
    full = os.path.realpath(os.path.join(base_dir, path))
    if not full.startswith(os.path.realpath(base_dir)):
        raise SecurityError("Path traversal detected")
    return full
```

Real-World Case: cherrystudio-qq-mcp

Two independently discovered CVEs:

- CWE-22: qq_upload_file(file_path) → open(file_path) without validation
- CWE-918: recognize_image(url) → requests.get(url) without URL validation

Tools: ,